

Riesgos y mejoras priorizadas

Nidokey / BuySell Asturias - 14 de junio de 2026

Este documento resume cada punto detectado, que significa para la app, que implicaciones tiene en funcionamiento, seguridad, rendimiento o mantenimiento, y que parte requiere una decision humana frente a lo que puedo ejecutar directamente por codigo.

P0 - 3 puntos Corregir antes de despliegues o cambios sensibles.	P1 - 5 puntos Planificar en el siguiente bloque de trabajo.	P2 - 5 puntos Mejoras importantes, sin bloqueo inmediato.	P3 - 4 puntos Limpieza, DX y reduccion de deuda tecnica.
--	---	---	--

Parte humana: decisiones de producto, politicas, secretos, infraestructura externa o validaciones que conviene aprobar. **Parte por codigo:** cambios que puedo implementar directamente en el repositorio, incluyendo tests, migraciones, workflows, documentacion y refactors acotados.

P0 - Riesgo critico

Bearer invalido termina en error 500 P0Seguridad QUE ES El middleware deja pasar peticiones con cabecera Bearer, pero si el token no es valido algunos handlers acaban lanzando una excepcion desde la resolucion de usuario. IMPLICACIONES La API puede devolver 500 en vez de 401. Esto empeora la UX de clientes externos, ensucia logs, dificulta depuracion y puede ocultar fallos reales de permisos. PARTE HUMANA Confirmar contrato de errores: 401 para no autenticado, 403 para autenticado sin permiso y 404 cuando convenga no revelar recursos. PARTE POR CODIGO Crear helper/wrapper de auth para handlers, devolver JSON consistente y añadir tests de tokens invalidos.	
Secreto de pagos reutiliza AUTH_SECRET P0Seguridad QUE ES La configuracion de webhooks o pagos puede caer en FOOD_PAYMENT_WEBHOOK_SECRET AUTH_SECRET, compartiendo un secreto de autenticacion general con una integracion de pagos. IMPLICACIONES Aumenta el radio de impacto si se filtra un secreto y complica rotaciones: cambiar pagos podria afectar sesiones o autenticacion principal. PARTE HUMANA Generar un secreto dedicado, cargarlo en entornos reales y decidir si hace falta rotar secretos existentes. PARTE POR CODIGO Hacer obligatorio FOOD_PAYMENT_WEBHOOK_SECRET, eliminar fallback, actualizar .env.example y cubrirlo con tests.	

No hay CI de PR para typecheck, tests y build

P0

DX / Operacion

QUE ES

El repositorio no tiene una validacion automatica completa en pull requests o pushes principales.

IMPLICACIONES

Cambios con errores de tipos, tests rotos o fallos de build pueden llegar a main y bloquear despliegues posteriores.

PARTE HUMANA

Activar secrets necesarios y, si se desea, reglas de proteccion de rama en GitHub.

PARTE POR CODIGO

Crear workflow de GitHub Actions con install, Prisma generate, typecheck, tests, lint y build segun scripts disponibles.

P1 - Prioridad alta

ownerId nullable en entidades multi-tenant

P1

Arquitectura

QUE ES

Algunas entidades permiten ownerId nulo aunque el sistema se basa en aislar datos por propietario.

IMPLICACIONES

Aumenta el riesgo de datos huérfanos, consultas difíciles de auditar y errores de aislamiento entre usuarios si una ruta olvida filtrar correctamente.

PARTE HUMANA

Decidir que usuario reclama datos huérfanos y si se permiten flujos anónimos temporales.

PARTE POR CODIGO

Preparar migración, script de reclamación, restricciones Prisma y tests de aislamiento por ownerId.

Rate limiting OTP solo por email

P1

Seguridad

QUE ES

El control de intentos de OTP se centra en el correo, pero no limita suficientemente por IP, dispositivo o ventana global.

IMPLICACIONES

Puede permitir bombardeo de emails o fuerza bruta distribuida, generando coste, ruido y fricción de seguridad.

PARTE HUMANA

Definir política de límites, duración de bloqueos y tolerancia para usuarios legítimos.

PARTE POR CODIGO

Añadir contador por IP/email con hash, ventanas temporales, respuestas 429 y tests de abuso.

Faltan tests de rutas críticas

P1

Calidad

QUE ES

Hay cobertura insuficiente para handlers de auth, pagos, comida, permisos y scraping.

IMPLICACIONES

Cambios pequeños pueden romper flujos de login, pedidos, importación o permisos sin detectarse hasta uso real.

PARTE HUMANA

Aprobar alcance de cobertura y si los tests usan mocks o base de datos de test.

PARTE POR CODIGO

Crear tests de integración enfocados, fixtures y comprobaciones de respuestas HTTP esperadas.

Busqueda global con contains insensitive

P1

Rendimiento

QUE ES

La busqueda depende de filtros tipo contains, que son simples pero escalan mal en tablas grandes.

IMPLICACIONES

A medida que crezca el catalogo, las busquedas pueden volverse lentas y consumir demasiada CPU en Postgres.

PARTE HUMANA

Aceptar una migracion de indices y decidir campos relevantes para ranking de busqueda.

PARTE POR CODIGO

Añadir busqueda full-text o indices GIN, adaptar consultas y medir planes antes/despues.

Recheck de anuncios secuencial y lento

P1

Rendimiento

QUE ES

El proceso checkAllActiveListings revisa anuncios uno a uno con pausas fijas.

IMPLICACIONES

Puede tardar demasiado, chocar con timeouts y dejar estados o precios obsoletos cuando el volumen suba.

PARTE HUMANA

Definir limites de concurrencia por portal y politica prudente de scraping para evitar bloqueos.

PARTE POR CODIGO

Implementar concurrencia controlada, backoff, metricas e ImportLog mas util para seguimiento operacional.

P2 - Prioridad media

Desfase entre documentacion BuySell y app Nidokey

P2

Arquitectura

QUE ES

La documentacion historica describe BuySell inmobiliario, pero el codigo ya incluye verticales como comida, chat y servicios.

IMPLICACIONES

Provoca decisiones inconsistentes, onboarding confuso y mayor riesgo de tocar piezas equivocadas.

PARTE HUMANA

Confirmar nombre, alcance actual y roadmap real del producto.

PARTE POR CODIGO

Actualizar README, AGENTS, roadmap y docs tecnicas para reflejar el estado actual.

Prefijo de tokens inconsistente: bs_ vs nk_

P2

Seguridad

QUE ES

Algunos documentos o scripts hablan de tokens bs_, mientras el codigo genera o espera nk_.

IMPLICACIONES

No es una vulnerabilidad directa, pero dificulta soporte, pruebas y depuracion de bookmarklets o clientes externos.

PARTE HUMANA

Elegir prefijo oficial para la marca actual y si se mantiene compatibilidad con tokens antiguos.

PARTE POR CODIGO

Unificar documentacion, comentarios, validadores y mensajes de error; añadir compatibilidad temporal si se decide.

OTP y magic links pueden imprimirse en logs dev

P2

Seguridad

QUE ES

Cuando falta Resend, el flujo de desarrollo puede mostrar codigos OTP o enlaces magicos en consola.

IMPLICACIONES

Es util en local, pero peligroso si ocurre por error en staging o produccion porque revela acceso en logs.

PARTE HUMANA

Decidir si staging permite modo debug o debe fallar si falta el proveedor de email.

PARTE POR CODIGO

Restringir logs sensibles a NODE_ENV=development y fallar rapido en produccion si falta configuracion.

Listado de pedidos carga eventos completos

P2

Rendimiento

QUE ES

La lista puede incluir eventos completos de muchos pedidos en vez de traer solo resúmenes.

IMPLICACIONES

El endpoint crece en peso y latencia, especialmente en mobile o dashboards con muchos pedidos.

PARTE HUMANA

Decidir que datos necesita realmente la lista frente al detalle de pedido.

PARTE POR CODIGO

Crear DTO de resumen, endpoint de detalle y pruebas para tamaño y forma de respuesta.

Scraping de menus borra y recrea items

P2

Rendimiento

QUE ES

La actualizacion de menus puede sustituir el menu completo en vez de aplicar diferencias sobre platos existentes.

IMPLICACIONES

Genera churn en base de datos, IDs inestables y mas riesgo para carritos, favoritos o referencias futuras a platos.

PARTE HUMANA

Definir regla de identidad de plato: nombre normalizado, categoria, variante, precio o combinacion.

PARTE POR CODIGO

Implementar upsert/diff estable, mantener IDs cuando sea posible y cubrir cambios con tests.

P3 - Mejora y deuda tecnica

IP LAN hardcodeada en la app mobile

P3

DX

QUE ES

El cliente mobile puede depender de una IP local concreta en vez de configurarse siempre por variable de entorno.

IMPLICACIONES

En otro equipo o red deja de funcionar sin tocar codigo, y es facil commitear valores locales por accidente.

PARTE HUMANA

Definir URL local recomendada para desarrollo fisico, simulador y entorno publicado.

PARTE POR CODIGO

Usar EXPO_PUBLIC_API_URL como fuente unica, actualizar ejemplos y mensajes de setup.

No hay script npm test estandar

P3

DX

QUE ES

Existen tests, pero falta un comando convencional npm test para que personas, agentes y CI los ejecuten igual.

IMPLICACIONES

Aumenta la friccion y hace mas probable que se omitan pruebas antes de subir cambios.

PARTE HUMANA

Aprobar convencion de runner y si se separan tests unitarios, integracion y smoke.

PARTE POR CODIGO

Añadir scripts npm coherentes y conectarlos con CI.

menu-scrape.ts concentra demasiadas responsabilidades

P3

Calidad

QUE ES

El modulo de scraping de menus mezcla resolucio de fuentes, extraccion, normalizacion y persistencia.

IMPLICACIONES

Los cambios son mas dificiles de razonar y testear, y se vuelve mas facil romper Google, Firecrawl o persistencia al tocar otra parte.

PARTE HUMANA

No requiere decision funcional, solo elegir el momento para el refactor.

PARTE POR CODIGO

Separar resolver, extractor, normalizador y persistencia, manteniendo comportamiento y tests de regresion.

orderCode usa Math.random

P3

Seguridad

QUE ES

El codigo corto de pedido se genera con una fuente pseudoaleatoria no criptografica.

IMPLICACIONES

El riesgo es bajo si solo se usa para soporte, pero conviene evitar codigos predecibles en identificadores visibles.

PARTE HUMANA

No requiere decision humana salvo cambiar formato visible del codigo.

PARTE POR CODIGO

Sustituir por crypto.randomInt o randomBytes y añadir tests de formato.